Université de Perpignan Année 2022
Licence 3 Informatique C. Negre

Contrôle Terminal 2

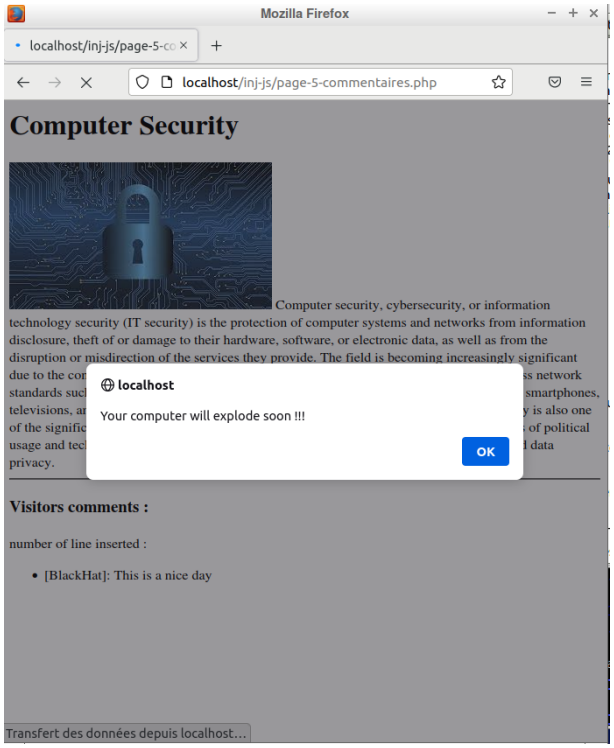
Sécurité Informatique

Recommandations.

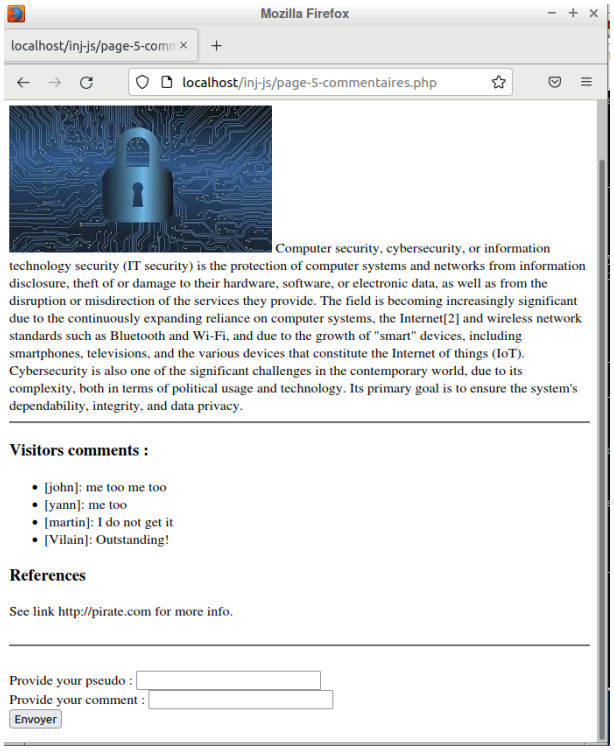
- Les notes de cours et de TD sont autorisés.
- Vous devrez rendre une copie électronique (en format .txt) de l'examen.

Exercice 1 (Vulnérabilités des applications web)**.** On considère la page web `page-5-commentaires.php` avec la base de données de `bd-table-commentaires.sql` (cf. archive exo1.tar).

1. Expliquez ce que fait la page.
2. Proposez une solution pour qu'un message d'alerte comme celui ci dessous s'affiche au chargement de la page.



3. Expliquez comment faire pour faire apparaître de facon frauduleuse une partie References comme dans l'image ci-dessous.



4. Comment peut-on eviter les injections des questions 2) et 3) dans la page web?

Exercice 2. On considère la page web `liste-taches-sql.php` avec les tables SQL données dans `bd-liste-taches.sql` (cf. archive exo2.tar). Cette page permet d'accéder à une liste de taches assignées à une personne d'une entretprise :

```
<html>

<body>
<form name="malveillant" method="POST" action="liste-taches-sql.php">
Entrez votre nom : <input name="UserLogin"> <BR/>
Entrez votre mot de passe : <input name="UserPW">
<input type="submit">
</form>



 <?php
$servername = "localhost";
$username = "l2info";
$password = "l2info";
$dbname = "l2info";

if( isset($_POST['UserLogin']) && isset($_POST['UserPW']) )
{


  // Create connection
  $conn = new mysqli($servername, $username, $password, $dbname);
  // Check connection
  if ($conn->connect_error) {
    die("Connection failed: " . $conn->connect_error);
  }
  echo 'Liste des taches de ' . $_POST['UserLogin'] . ':<BR>';
  $sql = 'SELECT Users.login,Taches.date,Taches.tache FROM Users INNER JOIN Taches ON
    Users.id=Taches.id WHERE login='' . $_POST['UserLogin'] . '"AND password='' .
    $_POST['UserPW'] . '";' ;
 // echo "requete =" . $sql . "<BR>";
  $result = $conn->query($sql);

```

```
33   if ($result->num_rows > 0) {
34   // output data of each row
35     while($row = $result->fetch_assoc()) {
36         echo "Login: " . $row["login"]. ", Date : " . $row["date"]. ", Tache :" .    $row
     ["tache"]."<br>";
37      }
38   }
39  else {
40   echo "0 results";
41   }
42 }
43 $conn->close();
44 ?>
45
46  </body>
47 </html>
```

Le mot de passe est vérifié pour restreindre l'accès, et n'afficher que les entrées d'un utilisateur.

1. Donnez les entrées du formulaire pour que l'on affiche l'intégralité de la table Taches.

2. Dans MySQL les données relatives aux utilisateurs et aux différentes tables des bases de données sont maintenu dans les tables de la base de données `information_schema`. Les tables de la base de données `information_schema` sont accéssible en lecture. Donnez les entrées du formulaire afin de lui faire afficher le nom des tables présents sur la base de donnée. Ces nom se trouve dans la table `TABLE_SCHEMA` de `INFORMATION_SCHEMA`. (Indication : utiliser l'opérateur `UNION` de SQL).

Exercice 3. On considère le code C suivant :

```
#include <stdio.h>
#include <stdlib.h>
#include <time.h>
#define N 20

void g()
{
  printf("on est dans la fonction secrete\n");
}
void f()
{
  unsigned long T[4];
  int i;

  T[0]=0;
  T[1]=1;
  T[2]=2;
  T[3]=3;

  printf("i=");
  scanf("%d",&i);
  printf("Old T[i]=%016lx\nNew T[i]=",T[i]);
  scanf("%lx",T+i);

  return;
}

int main()
{
  f();
  return(0);
}
```

1. Avec `gdb` analysez le code exécutable obtenu après compilation avec les options

   `-fno-stack-protector -fno-pie`

   et donnez pour la fonction `f`:

   - La taille de l'espace mémoire de la fonction `f` et les instructions servant à définir cet espace mémoire.
   - Les instructions servant à faire l'appel à `printf("i=");`.
   - Où se situent les éléments du tableau `T` ?

2. Comment dérouter le programme pour que la fonction `g` soient exécutée ?

3. Même question que la précédente mais sans l'option de compilation `-no-pie`.

Exercice 4. Dans l'archive `exo4.tar` vous trouverez les fichiers utiles à cet exercice. On considère le programme qui sert à visualiser des fichiers de transactions financières. Ce code est donné ci-dessous:

```c
#include <stdio.h>
#include <stdlib.h>
#include <crypt.h>
#include <string.h>

void hachage(char *passwd, char *pwd_hash)
{
  char md5[] = "$1$";
  char *hash;
  char *pw_hash;

  pw_hash = crypt(passwd, md5);
  //printf("pw_hash=%s\n",pw_hash+4);
  strcpy(pwd_hash,pw_hash+4);
}

int auth(char *nom, char *passwd)
{

  char pw_hash[100];
  FILE *f;
  char log[40],hash[40];
  //pw_hash = crypt(passwd, md5);
  hachage(passwd,pw_hash);
  printf("pw_hash=%s\n",pw_hash);

  // on parcourt le fichier pour trouver
  f=fopen("passwd.txt","r");

  while( ( fscanf(f,"%s",log) != EOF ) && ( fscanf(f,"%s",hash) != EOF ) )
    {
      //printf("log=%s, hash=%s\n",log,hash);
      if( (strcmp(log,nom) == 0  ) &&  (strcmp(hash,pw_hash) == 0  ) )
        {
          fclose(f);
          return(1);
        }
    }
  fclose(f);
  return 0;
}


int main(int argc, char **argv)
{
  char nom[8];
  char passwd[8];
  char annee[5];
  char command[50];

```

```c
  if( argc < 3)
    {
      printf("usage arg1=login , arg2=passwd\n");
      return(0);
    }
  else
    {
      strcpy(nom,argv[1]);
      strcpy(passwd,argv[2]);

      // verification que l on a les droits d'acces aux fichiers
      // avant de l'affichier
      if( auth(nom,passwd) == 1 )
        {
          // on fabrique la commande pour afficher le contenu du fichier
          strcpy(command,"cat ");
          printf("Entrez l annee des transactions:");
          scanf("%s",annee);
          strcat(command,annee);
          strcat(command,"-transactions.txt");
          printf("command=%s\n",command);
          system(command);
        }
    }
}
```

Voici brièvement ce que fait ce code:

- La fonction `auth`: les droits d'accès de l'utilisateur sont vérifié via leur mot de passe, et en comparant son haché avec celui stocké dans le fichier `passwd.txt`.
- La fonction `main`, après la vérification faite avec `auth`, le programme demande l'année $YYYY$ des transactions et affiche le fichier correspondant par la commande:

  ```
  user@pc:~$ cat   YYYY-transactions.txt
  ```

Répondre aux questions suivantes (elles sont indépendantes):

1. Proposez une solution (qui n'implique pas de débordement de tampon) pour que l'utilisateur puisse visualiser le contenu du fichier `passwd.txt`.
2. Avec un débordement de tampon, faites en sorte de ne pas faire de `cat` mais de lister le contenu du répertoire.
3. Connaissant les hachés des autres utilisateurs (qui se trouvent dans `passwd.txt`), en particulier du `admin`, faire un programme C qui hache les mots de passe les plus courants qui se trouvent dans le fichier `dictionnaire.txt` afin de retrouver celui de l'utilisateur `admin`. Vous pouvez réutiliser la fonction hachage du programme `affiche-transaction.c`.